



Handle-identitet på AT Protocol



Fra Auth0 til decentraliseret login på Aesthetic Computer

ATProto OAuth, handle-verifikation og portabel kreativ identitet

@jeffrey

Aesthetic.Computer

ORCID: 0009-0007-4460-4913

<https://aesthetic.computer>

[arbejdsudkast — ikke til citation]

Abstrakt. Aesthetic Computer autentificerer i øjeblikket brugere gennem Auth0 og opretholder en parallel identitet på en selvhostet AT Protocol Personal Data Server (PDS) på at.aesthetic.computer. Hver verificeret bruger modtager en DID og et PDS-handle, men autentificering foregår gennem en centraliseret OAuth-udbyder. Vi foreslår at sammenlægge denne duale identitetsarkitektur ved at adoptere AT Protocol OAuth [Bluesky PBC, 2024d] som primær login-metode, hvilket gør det muligt for alle med en Bluesky- eller ATProto-identitet at autentificere sig direkte og få det tilsvarende handle på Aesthetic Computer. Denne artikel gennemgår AT Protocol-identitetsstakken—DID'er, handle-verifikation, OAuth 2.1 med DPoP og PAR—undersøger, hvordan pckt.blog og andre ATProto-native applikationer implementerer decentraliseret login [pckt.blog, 2025], kortlægger den nuværende AC-autentificeringsarkitektur og foreslår en faseinddelt migration fra Auth0-afhængighed til AT Protocol-først-identitet. Det centrale argument: på en platform, der allerede kører sin egen PDS og udsteder sine egne DID'er, er den centraliserede identitetsudbyder det vestigiale organ. At fjerne den forenkler stakken, eliminerer en betalt afhængighed og gør AC til en førsteklasses borger i det fødererede sociale web.

1. INTRODUKTION

Identitet på webben er et udlejerproblem. Du ejer ikke dit handle på Twitter, dit brugernavn på Instagram eller

dit login på nogen platform, der kan slette din konto. AT Protocol [Bluesky PBC, 2024e]—den decentraliserede sociale netværksprotokol bag Bluesky—foreslår en anden ordning: din identitet er et kryptografisk nøglepar, dit handle er et domænenavn, du kontrollerer, og dine data ligger på en Personal Data Server, som du kan flytte mellem udbydere.

Aesthetic Computer har opereret med et hybrid identitetssystem siden 2024. Auth0 [Auth0 by Okta, 2024] håndterer autentificering: OAuth 2.0 med PKCE, refresh tokens og en administreret brugerdatabase. Separat udsteder en selvhostet PDS på `at.aesthetic.computer` ATProto-identiteter for hver verificeret bruger. Resultatet er et fordoblet system: to identiteter per bruger, to credential-lagre, to handle-synkroniseringsveje og et betalt Auth0-abonnement, der bygger bro over kløften.

Denne artikel spørger: hvad nu hvis PDS'en er identitetsudbyderen?

Svaret er ikke hypotetisk. `pckt.blog` [pckt.blog, 2025], en blogplatform bygget på AT Protocol, autentificerer brugere udelukkende gennem AT Protocol OAuth. Brugere logger ind med deres Bluesky-handle, deres selvhostede PDS eller enhver kompatibel identitetsudbyder. Ingen Auth0, ingen Firebase, ingen centraliseret brugerdatabase. Indholdet synkroniseres til brugerens egen PDS ved hjælp af delte lexicons fra Standard.site [Standard.site, 2025].

Vi undersøger, hvordan denne model gælder for Aesthetic Computer—en kreativ computing-platform med 600+ interaktive pieces, multiplayer-sessioner, et KidLisp-programmeringssprog og et native bare-metal OS [Jeffrey, 2026]—og foreslår en faseinddelt migration, der bevarer bagudkompatibilitet, mens den bevæger sig mod decentraliseret identitet.

2. NUVÆRENDE ARKITEKTUR

2.1 Auth0 som identitetsudbyder

Autentificering foregår gennem Auth0's SPA SDK. Ved sideindlæsning tjekker `boot.mjs` `localStorage` for cached Auth0-tilstand. Hvis en session eksisterer (eller et OAuth-callback detekteres), initialiserer den Auth0-klienten med PKCE og refresh tokens, udveksler autorisationskoder for access tokens og henter brugerprofilen. Auth0's `sub`-felt (f.eks. `auth0|abc123` eller `google-oauth2|xyz`) fungerer som den interne brugeridentifikator.

```
// boot.mjs: current Auth0 flow
const auth0 = await createAuth0Client({
  domain: "hi.aesthetic.computer",
  clientId: "LVdZaM...",
  cacheLocation: "localStorage",
  useRefreshTokens: true,
});
const user = await auth0.getUser();
// { sub, email, email_verified, ... }
```

2.2 Handle-systemet

Handles gemmes i en MongoDB `@handles`-collection, der mapper Auth0 `sub` til en streng på 1–16 alfanumeriske tegn (med `.` og `_` tilladt). Validering håndhæver ingen indledende/afsluttende tegnsætning, case-insensitiv unikhed og profanitetsfiltrering. Handles er den primære brugervendte identitet: URL-adresserbare (`@handle/piece-name`), synlige i chat og oplæst af AC Native OS.

2.3 ATProto-skyggeidentitet

Ved første e-mail-verifikation udløser en Auth0-webhook `createAtprotoAccount()`, som:

1. Genererer en adgangskode på 32 tegn
2. Opretter en invitationskode på PDS'en
3. Opretter en konto på `handle.at.aesthetic.computer`
4. Gemmer DID, handle og krypteret adgangskode i MongoDB (`users.atproto`)

Når en bruger ændrer sit AC-handle, synkroniserer `updateAtprotoHandle()` ændringen til PDS'en. Indhold (malerier, stemninger, KidLisp-snippets, tapes, nyheder) spejles til PDS'en via seks brugerdefinerede lexicons (`computer.aesthetic.*`). ATProto-identiteten er reel og funktionel—men brugeren autentificerer sig aldrig gennem den. Det er en skyggeidentitet: til stede, synkroniseret, men ikke suveræn.

2.4 Duplikeringsproblemet

Denne arkitektur medfører:

- To credential-lagre (Auth0 + PDS)
- To handle-navnerum (AC-handles + PDS-handles)
- To synkroniseringsveje (handle-ændringer propagerer Auth0 → MongoDB → PDS)
- En betalt afhængighed (Auth0-abonnement)
- Ingen interoperabilitet (en Bluesky-bruger kan ikke logge ind på AC med sin eksisterende identitet)

PDS'en ved allerede, hvem hver bruger er. Den gemmer allerede deres DID, deres handle, deres indhold. Auth0-laget tilføjer omkostninger og kompleksitet uden at tilføje kapabilitet, som PDS'en ikke kan levere.

3. AT PROTOCOL-IDENTITETSSTAKKEN

At forstå migrationen kræver forståelse af de tre lag i AT Protocol-identitet: DID'er, handles og OAuth.

3.1 Decentraliserede identifikatorer (DID'er)

En DID [W3C, 2022, Bluesky PBC, 2024b] er en persistent, kryptografisk verificerbar identifikator. AT Protocol bruger primært `did:plc`, en metode designet til stærk konsistens, høj tilgængelighed og nøglerotation uden tab af identitet. Hver DID opløses til et dokument, der indeholder:

- En **signeringsnøgle** (P-256 eller K-256) [Bluesky

[PBC, 2024a] til autentificering af repository-opdateringer

- **Rotationsnøgler** til kontogendannelse
- Et **PDS-endpoint** URL
- Brugerens aktuelle **handle**

DID'en er den stabile identitet. Handles ændrer sig; nøgler roteres; PDS-udbydere kommer og går. DID'en forbliver. AC udsteder allerede DID'er for hver bruger gennem sin PDS. Infrastrukturen eksisterer.

3.2 Handle-verifikation

Et AT Protocol-handle [Bluesky PBC, 2024c] er et domænenavn, der opløses bidirektionelt til en DID. Verifikation bruger to metoder:

DNS TXT: Placer en record på `_atproto.example.com`:

```
_atproto.example.com TXT "did=did:plc:abc..."
```

HTTPS Well-Known: Server DID'en på:

```
GET /.well-known/atproto-did
Response: did:plc:abc...
```

Begge metoder kræver, at handle opløses til DID'en *og* at DID-dokumentet hævder handle tilbage. Denne bidirektionelle verifikation betyder: hvis du kontrollerer domænet, kontrollerer du handle. Ingen central myndighed tildeler handles; DNS er myndigheden.

For AC betyder dette, at `jeffrey.at.aesthetic.computer` er et reelt, verificerbart ATPROTO-handle, fordi AC kontrollerer både DNS'en og PDS'en. Men det betyder også, at en bruger, der allerede ejer `alice.bsky.social` eller `alice.dev`, har en kryptografisk verificeret identitet, som AC kan stole på udtale p C kan DID-doku ET r

BFF2 #HQI 2M bi 2M; B 2M FQM
dX³"L1 aSß_:aJ³G
> M/H2@T`BQ`pBiBx2`m`2b2
K2MHb+2X#bFvXHQ;2HBM/- bF H
7`/2i\ 6à`bi iBH KàHH2 2`bBK
hS`QiQ@p2`B}+2`2i T`BQ`Bi2
7àD2`FQKTH2FbBi2iX
1@K BH@mi?yXH2p2`2`p2`B
iQ;2M/ MM2Hb2X hS`QiQ P m
aF H * F`ap2 2M 2@K BH iBH
MQiB}F iBQM2`V\
JmHiB@i2M*WìXBp2` 2M M/2
K2/ b2T`i mi?yX >pQ`/ M
B/2MiBi2i2` T`ip`b 7 i2M M
;MQbiBbF- ?pBHF2i F M 7Q`
i2M MibX

S.aö2M Fà`2` HH2`2/2X .A.ö2`M2 2`HmHbFV`S2`m/bi2`tiX+ bT2`?BiTb iBrQM pYXRX
G2tB+QM2`M2 2` HH2`2/2 Tm#HB+2`2iX2+2i2`iB/iBXR ikyb92#X .2+2Mi` HBx2/ A/2M
#`m;2`2 HQ;;2 BM/ ;2MM2K ?Qp2//à`2MXQ` h S`QiQ+QHX

h S`QiQ+QH@bT2+B}F iBQM2`, "Hm2bFv S"*X i T`QiQ+QH Q m?TbT2+B}+ iBQM

C ?iitb,ffr2#XTH+X/B`2+iQ`vfbT2+fpYARSG*@@H`
 bT2+B}F iBQM +QKfT +F ;2f! iT`QiQfQ mi?@+HB2Mi@MQX2X
 C ?iitb,ff iT`QiQX+OKf:mB/2bfG2iTB+QM@bE2K@
 C QiQ+QH P mi? +HB2Mi HB#` \vX

AKTH2K2Mi2`BM;b;mB/2`,
Ç ?iitb,ff/Q+bX#bFvX TTf#Hq;fq mlv;@hiS`QiiQ
P mi?@ ITb

P mi?@FHB2Mi;mB/2 QT2` iBM; bvbI2K- kykeX \*QKT MBQM T T2` /
LSJ@T FF2`, * L iBp2 PaX
C LiT`QiOfQ mi2@+HB2M022Yph P mi2@FHB2Mi; iem QG/GQ/iG/iG`P M t KT#SMH i i F

h2/L2Hb*QWxmi2`GB#f.`2KXa2BMO5m#HbB?
RND9X_2pBb2/2/BiBQM RN3d-h2KTmb"QQFb

Ç ?iitb,ffbi M/ `XbBi2f/Q+bfBmi`caimBiQ/MbBi2.2p2HQTK2MiDQm`M H QM hS`QiQ #HQ; BMi2
/2Hi2 H2tb+QMb L iaCBK m` -CQ?M`"/H2v- M/L p22M ;`rHX
TtHfE iBOM3/3`#m:3` hS`Qic mi2

Ç PzT`BMiX tT`EQHH#Q`iBp bF`BpMBM: ai M/`/XbBi2X ai M/`/bBi2, PT2M#HQ;Tm#HB
A1h6@bi M/`/2`, +QHXB,ffbi M/`/XbBi2f/Q+bfBM`kyk8Xa2/
Ç _6* N99N .SQS U.2KQMb`iBM;S`QQ7 Q`H3QB+b2Mb7QM`vHQ;+QM2MiTQ`i #BHBiv +`C

mi?y #v PFi X mi?y aBM;H2 S ?2i T TfamEX

1?yx+QKt/Q+bHb# B2bt mi?y@bBM:Hk9x2@11@b/F
C p a+`BTia.E 7Q` #`Qrb2`@# b2/ P mi? ~QrbX